

Welcome to BlackFile: Inside a Vishing Extortion Operation

 cloud.google.com/blog/topics/threat-intelligence/blackfile-vishing-extortion-operation

Google Threat Intelligence Group

May 15, 2026

Written by: Austin Larsen, Tyler McLellan, Genevieve Stark, Dan Ebreo

Introduction

Google Threat Intelligence Group (GTIG) has continued to track an expansive extortion campaign by UNC6671, a threat actor operating under the "BlackFile" brand, that targets organizations via sophisticated voice phishing (vishing) and single sign-on (SSO) compromise. By leveraging adversary-in-the-middle (AiTM) techniques to bypass traditional perimeter defenses and multi-factor authentication (MFA), UNC6671 gains deep access to cloud environments. The group primarily targets Microsoft 365 and Okta infrastructure, leveraging Python and PowerShell scripts to programmatically exfiltrate sensitive corporate data for subsequent extortion attempts. This post details UNC6671's attack lifecycle and provides defenders with actionable guidance to detect and mitigate these identity-centric threats.

Since emerging in early 2026, UNC6671 has maintained a high operational cadence. GTIG assesses that the group has targeted dozens of organizations across North America, Australia, and the UK.

GTIG previously highlighted UNC6671 as a distinct cluster in a prior report detailing similar SaaS data-theft techniques utilized by ShinyHunters (UNC6240). While UNC6671 has co-opted the ShinyHunters brand in at least one instance to inject artificial credibility into their threats, GTIG assesses that the operations are independent. This distinction is supported by UNC6671's use of separate TOX communication channels, unique domain registration patterns, and the launch of a dedicated "BlackFile" data leak site (DLS).

These compromises are not the result of a security vulnerability in vendor products or infrastructure. Instead, this campaign continues to highlight the effectiveness of social engineering and underscores the critical importance of organizations moving toward phishing-resistant MFA to protect their SaaS and identity platforms.

Initial Access

UNC6671 initial access operations rely on high-volume voice phishing (vishing), often characterized by meticulous social engineering tactics, synchronized with real-time credential harvesting. These vishing calls are typically made by "callers" hired by the threat actor.

IT Deployment Pretext

The callers often call targeted employees' personal cellular phones to bypass security tooling and move the victim away from standard support channels. They typically masquerade as internal IT or help desk personnel, citing a mandatory migration to passkeys or a required multi-factor authentication (MFA) update. This pretext justifies directing the victim to a credential harvesting site and provides a logical cover for any subsequent security alerts generated during the compromise. UNC6671 has shifted from unique, organization-tailored credential harvesting domains to a subdomain-based model. These domains are typically registered with Tucows. Recent campaigns have used subdomains explicitly referencing "passkey" or "enrollment" themes to enhance the legitimacy of the help desk pretext.

- <organization>.enrollms[.]com
- <organization>.passkeyms[.]com
- <organization>.setupssso[.]com

Real-Time MFA Interception

The vishing call functions as a live adversary-in-the-middle (AitM) attack. The process follows a rapid, procedural lifecycle:

- **Redirection:** The victim is directed to a lookalike subdomain mirroring the organization's single sign-on (SSO) portal.
- **Credential Capture:** As the victim inputs their username and password, the threat actor captures these in real-time and immediately submits them to the legitimate SSO provider.
- **MFA Bypass:** When the legitimate portal issues an MFA challenge (Push, SMS, or TOTP), the victim—believing they are completing a setup step—provides the code or approval to the threat actor.
- **Device Registration:** Upon gaining access, the threat actor immediately navigates to the user's security settings to register a new, attacker-controlled MFA device to ensure persistence.

The speed of this execution ensures the threat actor can establish a permanent foothold before the victim or the organization's Security Operations Center (SOC) can identify the

anomaly.

Data Theft

Following successful authentication, UNC6671 leverages SSO access to move laterally across the victim's SaaS applications to enable data theft operations. The threat actors appear to be focused on targeting Microsoft 365 and Okta environments, using compromised accounts to access SharePoint, OneDrive, and other connected SaaS applications such as Zendesk and Salesforce. In several instances, the actors specifically queried internal search functions for string literals such as "confidential" and "SSN" to prioritize theft of perceived high-value data.

Programmatic Data Exfiltration

Upon establishing persistence, UNC6671 transitions from interactive browser-based reconnaissance to automated exfiltration. In multiple engagements, we observed the use of scripts to harvest high-value data from SharePoint and OneDrive repositories.

In addition to relying on methods that triggered standard FileDownloaded events, the threat actor has also used less conspicuous approaches. These include the threat actor's use of formal APIs, such as Microsoft Graph, as well as the python-requests library and PowerShell to issue direct HTTP GET requests against document resource URLs. Notably, by repurposing valid session cookies (e.g., FedAuth) captured during the initial vishing phase, the actor has been able to "stream" file content directly to attacker-controlled infrastructure.

In these cases, the request mimics a standard web client fetch rather than a formal "Download" command. As a result, the activity is frequently recorded as a FileAccessed event rather than FileDownloaded. This 'direct fetch' method naturally blends into routine traffic, which may bypass detection in many Security Operations Centers (SOCs) that prioritize FileDownloaded events and treat FileAccessed as benign.

Forensic Artifacts and Scripting

Analysis of Microsoft 365 Unified Audit Log (UAL) telemetry revealed several consistent forensic indicators of UNC6671 activity, including clear evidence of scripted exfiltration. Most notably, the threat actor frequently showed User-Agent mismatches; while they spoofed the ClientAppId for "Microsoft Office" to bypass basic conditional access filters, the recorded UserAgent strings identified scripting engines such as python-requests/2.28.1 or WindowsPowerShell/5.1. This discrepancy suggests that access was driven by automated scripts rather than human interaction with the SharePoint user interface. Additionally, these

access attempts consistently originated from non-standard infrastructure, such as commercial VPN exit nodes and hosting providers.

```
{
  "CreationTime": "2026-02-24T14:36:15",
  "Operation": "FileDownloaded",
  "Workload": "SharePoint",
  "ClientIP": "179.43.185.226",
  "UserId": "victim.user@organization.com",
  "UserAgent": "python-requests/2.28.1",
  "ApplicationDisplayName": "Microsoft Office",
  "IsManagedDevice": false,
  "SourceFileName": "2382_REDACTED_MSA_v3.docx",
  "SourceRelativeUrl": "Shared Documents/Legal/MasterMSA/Archive",
  "SiteUrl": "https://organization.sharepoint.com/sites/Legal_Archive/",
  "AppAccessContext": {
    "ClientAppId": "d3590ed6-52b3-4102-aeff-aad2292ab01c",
    "ClientAppName": "Microsoft Office",
    "TokenIssuedAtTime": "1601-01-01T00:00:00"
  }
}
```

Figure 1: FileDownloaded event observed in early UNC6671 intrusions

```
{
  "CreationTime": "2026-03-18T20:06:41",
  "Operation": "FileAccessed",
  "Workload": "SharePoint",
  "UserId": "victim.user@company.com",
  "ClientIP": "179.43.185.226",
  "UserAgent": "python-requests/2.28.1",
  "ApplicationDisplayName": "python-requests",
  "IsManagedDevice": false,
  "SourceRelativeUrl": "Shared Documents/Data Analytics/Power BI Version History",
  "SourceFileName": "Weekly Production Report.pbix",
  "SiteUrl": "https://company.sharepoint.com/sites/ProductionOps/",
  "AppAccessContext": {
    "ClientAppName": "python-requests",
    "CorrelationId": "b94b01a2-2019-c000-2262-5ff1d0ff6cc8"
  }
}
```

Figure 2: FileAccessed event from later UNC6671 intrusions

The speed and scale of UNC6671's data exfiltration also reflects the automated nature of these scripts, which allows the threat actors to exfiltrate massive volumes of data at high speeds. In one case, the threat actor used their Python script from a remote IP to access and download over a million individual files from a victim's SharePoint and OneDrive

environments. In another case, the threat actor rapidly iterated through tens of thousands of SharePoint file interactions.

Extortion

UNC6671 conducts highly targeted extortion campaigns, beginning with unbranded ransom notes sent from programmatically generated consumer email accounts. Once a victim engages via the unique, encrypted communication channel (such as Tox or Session) provided by the threat actor in the initial ransom note, the operators identify themselves under the "BlackFile" brand. While the operators typically open negotiations with initial demands in the millions of dollars, they often pivot to low six-figure demands when met with active engagement. Notably, while the initial emails typically do not contain errors, at least some follow up emails have contained mistakes suggesting that those are human generated.

In cases where the operator is met with silence or resistance, the group aggressively escalates pressure. During a recent incident, after the victim was unresponsive, UNC6671 pivoted to an aggressive spam campaign. Using dozens of Gmail accounts with randomly generated usernames, the threat actor flooded employee mailboxes with messages before automated restrictions kicked in based on their sending behavior and their accounts were restricted. We have also observed these threat actors sending threatening voicemails to C-suite executives and, in severe cases, utilizing swatting tactics against company personnel.

Subject: [COMPANY NAME] DATA BREACH 72 HOURS TO CONTACT US

From: [pseudorandom_alphanumeric_string]@gmail.com

Hello [Company Name] Executives and HR,

We have managed to export ~[X] TB of data from your network due to your terrible security practices and negligent data storing practices.

Here is a brief overview of data exported from your network:

1. [X]+ GB of internal company files (SharePoint & OneDrive) containing confidential business processes, NDAs, project cost estimates, subcontractor contracts, and HR records.
2. Tens of thousands of emails from executive mailboxes, including confidential documents.
3. Complete CRM and support ticket exports (Salesforce & Zendesk) containing hundreds of thousands of customer records, PII, billing details, and communication logs.

4. Complete corporate directory (Entra) dumps including employee names, mobile numbers, job titles, and hierarchy.
5. ~[X] ServiceNow IT infrastructure records (computers, servers, cloud resources).

You have exactly 72 hours to contact the [Tox / Session] ID provided below. If you fail to contact the ID provided by us within the timeframe stated, we will be forced to publish your data to the public. We will also be forced to contact each company you work with via the employee team contact phone numbers and email addresses provided and explain how [Company Name] has terrible security protocols and does not care about its customers.

We are willing to engage in good faith negotiation terms. Upon contacting us, a full list of all data exported from your network will be sent to you for review. You will be able to pick up to 3 files to confirm and verify we have what we are claiming.

[Tox / Session] ID: [Unique Alphanumeric String]

Silence may not always be wise in situations like this. We will not be ignored. Make the right choice and cooperate with us so this can be a learning experience for you.

Figure 3: Generalized example initial unbranded extortion note from UNC6671

Subject: [COMPANY NAME] DATA BREACH 72 HOURS TO CONTACT US

From: [pseudorandom_alphanumeric_string]@gmail.com

Dearest executive,

You have picked to ignore the first deadline to contact us. That is not smart do not ignore us it will only make things worse. We are BlackFile. Do not play games with us. We are giving a final deadline of 72 hours to contact us so we can reach an agreement.

We copied over [X] TB+ of data from your SharePoint & M365 instance (legal documents, operational documents, client documents, sales documents, development documents, etc) over [X]gb of Salesforce data, full ZenDesk support ticket export for [X]+ customers, ALL ticket history including old and new tickets and their contents. Total taken from your network is over [X]TB+

Do not be alarmed as you can secure the protection of your data by choosing to work with us. Nothing taken from your network has been disclosed to the public or shared with third parties as of now.

Reach out to us on session to receive all details and evidence that we accessed your network. We will use Session to communicate with you. You can get Session by visiting

getsession(.)org

Reach out to the following ID using Session: **[Unique Session ID]**

Do not reply to this email. Instead alert the rest of your HR and SOC/IT Security Team. We give you a final deadline of 72 hours to confirm receipt that you received this email by contacting us on Session.

If you fail to contact us a second time then a majority of the emails taken from your network will receive a notification from us explaining you failed to come to an agreement with us to protect your customers PII and other sensitive information. Additionally we will message journalists about this breach and your failure to come to a resolution with us before finally uploading all data taken from you to our blog for the public.

Do not let a data recovery company tell you not to negotiate us we are BlackFile and we do not play games. The data we took from you can seriously damage your reputation if released is it really worth having that happen over ignoring us?

Blackfile

Figure 4: Generalized example follow up extortion email which included branding not present in initial messages

Evolution of Ransom Notes

Throughout their operations in early 2026, UNC6671's ransom notes exhibited an evolution in formatting, branding, and communication methods. Initially, the threat actors used highly aggressive, short-term deadlines, often giving early victims generic 24 or 48 hour windows to respond. This appeared to become more standardized in late January when they gave subsequent targets a strict 72-hour deadline. Their email subject lines also evolved into a formalized, all-caps structure: [COMPANY NAME] DATA BREACH 72 HOURS TO CONTACT US.

During this same period, the group's identity and preferred communication channels shifted. Early extortion emails were unbranded, with the actors demanding contact via Tox (a peer-to-peer instant messaging protocol). By February 2026, the group formally adopted the "BlackFile" moniker and transitioned their communication demands exclusively to Session (a decentralized, privacy-focused messenger), providing victims with Session IDs and client download instructions. Additionally, while early extortion notes were sent from external emails that could easily be flagged by spam filters or ignored, since at least March 2026, UNC6671 has leveraged hijacked internal corporate email and Microsoft Teams accounts.

The BlackFile Data Leak Site (DLS)

The threat actors launched the BlackFile Data Leak Site (DLS) on February 6, 2026, claiming to operate as "security researchers." Despite maintaining a dedicated DLS, the group's approach to data exposure deviates significantly from the maximum-publicity, high-noise model employed by other actors. UNC6671 does not publicly advertise their leak site or attempt to index it for search engines. Furthermore, the group has typically only leaked limited file samples and directory listings rather than full datasets; to date, GTIG has not observed the actor leak victim data in full.

Figure 5: BlackFile DLS

Figure 6: BlackFile DLS Deletion Process

Notably, the BlackFile DLS site went offline in late April 2026, but briefly came back online on May 11, 2026 to share the below message before shutting down again. In this message, the threat actor stated "BlackFile is shutting down... under this name." As of the time of publication, the DLS site is inaccessible.

Figure 7: BlackFile DLS Shutdown Announcement

Remediation and Hardening

GTIG recommends the following mitigations and hunting strategies:

- **Deploy Credential Guarding:** Configure environment-specific protections to catch credential submission at the point of impact. In Google Workspace, enable Password Alert to monitor for corporate password hashes being entered into unauthorized domains. For Microsoft environments, leverage Microsoft Defender's Credential Protection and SmartScreen to intercept submissions on known phishing or low-reputation sites. These automated technical controls act as a final fail-safe, triggering immediate password resets or security alerts when a user inadvertently interacts with a malicious page.
- **Implement Phishing-Resistant MFA:** Transition away from SMS-based or push-notification MFA. Implement FIDO2-compliant security keys or passkeys, which are resistant to the adversary-in-the-middle (AiTM) and vishing tactics employed by UNC6671.
- **Monitor IdP Logs:** Review identity provider logs for `system.multifactor.factor.setup` events that are immediately preceded by `user.authentication.auth_via_mfa` failures or "Abandoned" challenges.

- **Correlate Infrastructure:** Alert on authentication attempts originating from known commercial VPNs or hosting providers that are abnormal for the user's typical geographic location.
- **Audit SaaS API Activity:** Monitor Microsoft 365, SharePoint, and Salesforce audit logs for anomalous, high-volume file downloads (FileDownloaded or FileAccessed events) originating from generic scripting user agents (e.g., PowerShell, Python).
- **Monitor User-Agents:** Monitor for specific IdP SDK User-Agents on devices not previously associated with a user's profile.
- **Re-Evaluate "Access" Severity:** Security Operations Centers (SOCs) should treat FileAccessed events with the same criticality as FileDownloaded when the User-Agent identifies it as a programming library (Python, Go, etc.) or a command-line tool.
- **Audit for Direct File Streaming:** Monitor for FileAccessed logs where the AppAccessContext indicates a headless client or where the volume of "Accessed" files in a short window exceeds human browsing capability.

Outlook and Implications

The recent shutdown of the BlackFile data leak site (DLS) accompanied by the actors' own declaration that they are shutting down "under this name" signals a possible transition phase rather than a permanent cessation of their threat activity. Historical precedents across the extortion ecosystem demonstrate that major threat clusters commonly rebrand or disperse their operations following disruption or voluntary shutdowns. These events can serve several strategic functions: evading law enforcement or competitor scrutiny, quietly resolving pending extortion cases, or preparing to pivot to a more viable brand while simultaneously also allowing time for the threat actors to retool and/or set up new infrastructure. Even if the BlackFile brand is permanently retired, the techniques leveraged by UNC6671, specifically their focus on data theft from cloud and SaaS environments, represent a highly successful trend in the cyber crime threat landscape that we also highlighted in the Google Cloud H1 2026 Cloud Threat Horizons Report. Organizations can review our prior blog post with actionable hardening, logging, and detection recommendations to help protect against these threats.

Indicators of Compromise (IOCs)

To assist the wider community in hunting and identifying activity outlined in this blog post, we have provided indicators of compromise (IOCs) in a free GTI Collection for registered users.

At the time of publication, identified phishing domains have been added to Google Safe Browsing.

While this collection provides a comprehensive list of IOCs, defenders should note that the majority of identified IP addresses are commercial VPN nodes, and actual source IPs tend to vary as the actor continuously cycles through new infrastructure. Furthermore, the domains are often stood up and used within minutes of registration; as such, they are provided primarily as examples of past naming conventions and usage patterns rather than as a primary mechanism for real-time blocking.

Google Security Operations (SecOps)

Google SecOps customers have access to broad category rules under the Okta and O365 rule packs that detect the behaviors outlined in this report. The activity discussed in the blog post is detected in Google SecOps under the following rule names:

- Okta Admin Console Access Failure
- Okta Suspicious Actions from Anonymized IP
- O365 SharePoint Bulk File Access or Download via PowerShell
- O365 SharePoint High Volume File Access Events
- O365 Sharepoint Query for Proprietary or Privileged Information

Posted in

Threat Intelligence